



Information Security Policy

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S item: EV6 (information security policy), also evidences Q7 (management- endorsed security policy) and GO1 (named security officer) **Version:** 0.1 DRAFT · **Date:** 2026-07-24 **Status:** Draft for review — not yet signed

1. Purpose and scope

This policy is Lumi Reading's top-level statement of intent for protecting the personal information it holds — principally the reading and learning data of school children — and the systems that process it. It records management's commitment to information security, the legal obligations Lumi accepts, the governance roles that own security and privacy, and the mandatory controls every person working on Lumi must follow. It sits above, and points to, the operational documents that implement it (§9); those documents carry the file-cited technical detail and this policy does not repeat it.

Scope: everyone who builds, operates or supports Lumi (currently the Director, plus any contractor or adviser engaged), and every system in the estate — the Flutter app (`lib/**`), Cloud Functions (`functions/**`), the privileged core (`packages/server-ops/**`), the two Next.js portals (`school-admin-web/` , `admin/`), the marketing site (`marketing-site/`), the security rules (`firestore.rules` , `storage.rules`), and the data held in the `lumi-ninc-au` Google Cloud project (`australia-southeast1`). It also covers the third-party services Lumi relies on, through the vendor-management requirements in §8.

2. Management commitment

Lumi's management (the Director) is accountable for information security and commits to:

- treating the protection of children's personal information as a primary design and operating constraint, not an afterthought;
- resourcing and maintaining the controls in the operational documents this policy points to (§9), and the assessment and remediation programme that produced them (`docs/security/SECURITY_ASSESSMENT_ORCHESTRATION_PLAN.md` , `docs/ST4S_REMEDIATION_PLAN_2026-07-22.md`);
- reviewing this policy at least annually and after any material change or significant incident (§10);
- appointing and empowering the named security and privacy officers (§4).

This commitment is expressed as policy; it becomes governing only once signed (this is a draft, §11).

3. Legal and regulatory compliance

Lumi operates under Australian law and commits to comply with:

- the **Privacy Act 1988 (Cth)** and the **Australian Privacy Principles (APPs)**, including APP 8 (cross-border disclosure) obligations for the overseas services Lumi uses (Firebase Authentication is US-only; FCM, App Check, Analytics/Crashlytics and SendGrid are cross-border — each is inventoried and carries a required APP 8/contractual review in the vendor register, [docs/security/AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md](#));
- the **Notifiable Data Breaches (NDB) scheme** — breach assessment and notification are governed by the incident response plan and the underlying breach-response plan (§7);
- the **Student Data Privacy / Safer Technologies 4 Schools (ST4S)** assessment requirements against which this evidence pack is prepared.

Lumi's primary child-content plane (production Firestore, user-content Storage, all live Functions/Cloud Run) is hosted in Sydney ([australia-southeast1](#)); the documented cross-border exceptions and their review status are in the resource- location audit. Where a Lumi control depends on a legal determination — most importantly an NDB notification decision — the decision is reserved to qualified Australian privacy counsel and is **not** asserted as an in-house capability (§4, §11).

4. Governance roles (GO1 / GO2)

Two named roles own this policy in practice. While Lumi is small one person may hold both, but the responsibilities are distinct and every privileged action is recorded.

Role	ST4S	Owns	Holder
Security Lead	GO1	This policy; the technical controls, secure SDLC, access control, monitoring, incident detection/containment; the security assessment and findings register	Nic (Director)
Privacy Officer	GO2	Privacy compliance (APPs), the PIA/vendor register, cross-border (APP 8) assessments, NDB assessment coordination with external counsel, data-subject/school privacy enquiries	Nic (Director)

NOTE — appointment letters pending signature. The formal GO1/GO2 appointment letters that back these roles are **drafted but not yet signed**; [docs/security/ASSESSMENT_STATUS.md](#) records GO1/GO2 as *Not Ready*. The operational role assignments are already in effect (they are exercised in the access-control policy, the SDLC, the incident-response plan and the breach tabletop), but the signed letters are the outstanding governance artefact and must be executed for GO1/GO2 to be true (§11). The Privacy Officer's NDB / OAIC-liaison function additionally requires engaging external Australian privacy counsel (see the incident-response plan §2, §8).

5. Least privilege and mandatory MFA for privileged access

- Deny-by-default, server-defined authorization.** Access to child, class and school data is governed by the Firestore/Storage security rules and server-written role fields — never by a client-asserted claim. A signed-in principal with no membership document is denied; there is no ambient access. The full model, the deployed create-time field-lock fixes (F-01...F-04) and the proven cross-tenant isolation are in the access-control policy ([docs/security/evidence/ACCESS_CONTROL_POLICY.md](#), [firestore.rules](#)).
- Mandatory MFA for privileged accounts.** School administrators must complete authenticator (TOTP) MFA before the portal issues a session cookie; a password-only or SMS-only admin token is rejected until enrolment finishes, and any pre-rollout admin cookie is invalidated ([docs/ADMIN_TOTP_MFA_RUNBOOK.md](#)). At

least two active administrator accounts are kept so recovery never depends on a locked-out person, and no administrator may disable their own final factor from an active session.

- **Least-privilege infrastructure identities.** Cloud Functions and each portal run under dedicated runtime service accounts (not the default App Engine account); the admin auto-deploy authenticates keylessly via GitHub OIDC / Workload Identity Federation with a predeploy identity audit that refuses the deploy on privilege drift (`.github/workflows/admin-deploy.yml`, `infra/iam/audit-admin-build-identity.sh`).
- **No secrets in clients, builds or logs.** Secrets, Admin credentials and billable unrestricted keys must not enter a client, build artifact, log or Remote Config; this is enforced in CI by secret scanning over the full git history (`.github/workflows/secret-scan.yml` ; history is gitleaks-clean).

6. Acceptable use

Everyone with access to Lumi systems or data must:

- use access **only** for authorised Lumi operational and support purposes;
- protect their credentials, keep MFA enabled on every privileged account, and never share accounts or session cookies;
- keep the endpoints they use to access production reasonably secured and current (the device standard is a pending companion document — A10, §11);
- never place a secret, private key or personal information into source control, a build, a log, a transcript or a support ticket;
- handle child personal information on a strict need-to-know basis, and never export or copy it outside approved systems;
- report anything that looks like a security or privacy problem promptly (§7).

Misuse of access to Lumi data is treated as a serious matter and may end a person's access and engagement.

7. Duty to report incidents

Any suspected or confirmed security or privacy incident — a possible data exposure, a lost or compromised credential or device, a suspicious access pattern, a scanner or researcher report — **must be reported without delay** to the Security Lead. Reporting is a duty, not a discretion, and good-faith reports are never penalised. The response is then governed by the incident response plan

(`docs/security/evidence/EV9_INCIDENT_RESPONSE_PLAN.md`), which defines detection channels, triage/severity, containment, eradication, recovery, the NDB notification assessment (led with external counsel), the incident register, and the blameless post-incident review. External reports are received at the monitored, MFA-protected support intake mailbox recorded in that plan (a role mailbox, not a personal address).

8. Third-party and supply-chain security

- **Vendor register.** Every third-party service that processes Lumi data is inventoried with its processing location and cross-border/APP 8 status. The live inventory of platform services and their exception status is `docs/security/AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md` ; the standing vendor / PIA register is maintained on the recurring schedule in `docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md` (quarterly vendor/PIA review).
- **Assess before adopting.** A new SDK, dependency or processor that touches personal information is not adopted until its data flow, processing location, sub-processors and a written data-processing/APP 8 position have been reviewed and recorded — this is a required item on the release privacy/security review

gate. Data-sharing and written data-processing agreements are tracked as ST4S PR10 / PR17 / INT7 items (a separate privacy workstream requiring privacy counsel — §11).

- **Supply-chain integrity in the pipeline.** Dependencies are centrally updated and scanned (Dependabot + osv-scanner SCA + semgrep SAST + production `npm/pnpm audit`), and remediated under the patch-management process (`docs/security/evidence/EV12_PATCH_MANAGEMENT.md`, `docs/security/evidence/EV13_SECURE_SDLC.md`).

9. Policy framework — documents this policy governs

This policy is the apex; the operational controls live in, and are evidenced by:

Area	Document
Access control, least privilege, review (A6/A7/A13/A5)	<code>docs/security/evidence/ACCESS_CONTROL_POLICY.md</code>
Secure development lifecycle + CI security gates (EV13/Q5)	<code>docs/security/evidence/EV13_SECURE_SDLC.md</code>
Patch management (EV12/T2/T3)	<code>docs/security/evidence/EV12_PATCH_MANAGEMENT.md</code>
Monitoring + security testing (T1/AP1)	<code>docs/security/MONITORING_PLAN.md</code>
Incident response + register + breach notification (EV9/T6/T7)	<code>docs/security/evidence/EV9_INCIDENT_RESPONSE_PLAN.md</code> , <code>docs/privacy/DATA_BREACH_RESPONSE_AND_TABLETOP.md</code>
Business continuity (EV7)	<code>docs/security/evidence/EV7_BUSINESS_CONTINUITY_PLAN.md</code>
Disaster recovery (EV8/D3)	<code>docs/security/evidence/EV8_DISASTER_RECOVERY_PLAN.md</code>
Privileged MFA runbook (A5)	<code>docs/ADMIN_TOTP_MFA_RUNBOOK.md</code>
Release privacy/security review gate	<code>docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md</code>

10. Review and maintenance

- This policy is reviewed **at least annually**, and additionally after any material change to the estate, any change of holder for a governance role, or any significant security or privacy incident.
- The recurring operational reviews that keep the underlying controls honest — weekly automated security review, monthly IAM/keys review, quarterly vendor/PIA review, six-monthly breach tabletop — are defined in `docs/privacy/RELEASE_PRIVACY_SECURITY_REVIEW.md` and evidenced by the CI workflows in `.github/workflows/`.
- Each review is recorded with a date, the reviewer, and any change; the version and date at the head of this document are bumped on every substantive change.

11. Known gaps (for the reviewer)

- **GO1/GO2 appointment letters pending signature.** The named Security Lead and Privacy Officer roles are operationally assigned but the formal appointment letters are **unsigned** (`ASSESSMENT_STATUS.md` records GO1/GO2 as *Not Ready*). This is the top governance gap: until the letters are signed, GO1/GO2 cannot be claimed as met.
- **External privacy counsel for NDB / APP 8.** The Privacy Officer's breach- notification and cross-border-assessment functions require engaging qualified Australian privacy counsel; this policy must not be read as asserting an in-house NDB decision capability.
- **Device standard (A10) pending.** §6 references a companion endpoint/device standard that is drafted-but-pending; confirm it is completed and adopted.
- **Privacy pack pending (PR2/PR10/PR17/INT7).** The public privacy policy, sub-processor disclosure, data-sharing audit and written data agreements are a separate privacy-counsel workstream and are not yet complete; §3/§8 reference the obligations, not completed artefacts.
- **Sign-off.** This policy requires the Director's signature (and the signed GO1/GO2 letters) before it is the governing document.